LABORATUVAR 5 · PAKETPRO 3000 · Paketleme Makinesi

SBOM / CVE / Patch

Çıktı: Vulnerability Decision

Ad Soyad Beşir Can Barutçu | Grup | Tarih 06.11.2026

Kavram: SBOM = yazılım malzeme listesi · **CVE** = açığın kayıt no'su · **CVSS** = ciddiyet (0–10). Bir CVE sizi etkiler mi? Üç şart: bileşen **var**, sürüm **etkileniyor**, açık **ulaşılabilir**.

Verilen zafiyet kaydı

Bileşen	PaketPro Component X (PLC firmware kütüphanesi)
Sürüm	2.4
CVE	CVE-XXXX-XXXX
Önem	Critical (CVSS 9.8)
Yama	Mevcut

Görev — karar akışı

1. Bu CVE sizi gerçekten etkiliyor mu? (üç şartı kontrol edin)

   Üç şart: (1) Bileşen var mı? SBOM'a bakılır: Component X, Gradius hat PLC'si firmware'inde var (varsayım, KANTEC SBOM'u ile doğrulanacak). (2) Sürüm etkileniyor mu? Bizde 2.4, etkilenen sürüm. (3) Ulaşılabilir mi? PLC'ye IPC üzerinden (C3), bugünkü düz ağda uzak servisten (C6) de ulaşılıyor. Üçü de evet: bizi etkiliyor.

2. Üretimi hemen durdurur musunuz? Neden / neden değil?

   Hayır, hemen durdurmayız. CVSS 9.8 siber ciddiyeti gösterir, insana etkiyi değil; açık safety yolunu (Safety PLC → STO, Z5) değil hat PLC'sini etkiliyor. Önce erişimi kısarız (uzak servis kapalı, C3'te sadece gerekli trafik). İstismar belirtisi veya safety etkisi görülürse hat kontrollü durdurulur.

3. Yamayı doğrudan mı uygularsınız, önce test mi? Nerede test?

   Önce test. Yama KANTEC'in test standında, aynı firmware ve programla yedek PLC'de denenir. Sonra planlı bakım duruşunda, önce yedek alınarak (EP 12) uygulanır; geri dönüş planı hazırdır. Doğrudan üretim hattında denenmez.

4. Bu yama bir safety validation etkiliyor mu? Nasıl anlarsınız?

   Hat PLC'si safety fonksiyonunu yürütmez ama reset/mod sinyali ve tepsi (muting) bilgisi verir. Anlamak için: yama notları ve SBOM'da değişen modüller incelenir, Safety PLC konfigürasyonunun CRC'si yama öncesi/sonrası karşılaştırılır, SF1–SF5 tekrar test edilir. Safety PLC firmware'ine dokunuyorsa yeniden validation zorunlu.

5. Yama mümkün değilse compensating control (telafi edici önlem) ne olur?

   Telafi edici önlemler: PLC'ye ağ erişimini firewall ile sadece IPC'ye kısıtla (C3), uzak servisi varsayılan kapalı tut, açığın kullandığı servisi/portu kapat, anomali izleme (IDS) ekle, PLC'yi program değişikliğine kilitli tut. Karar ve gerekçe Vulnerability Records'a (EP 10) yazılır, yama tarihi planlanır.

Bu föyün çıktısı **Vulnerability Decision** → Evidence Pack **EP 09 · 10 · 11** başlığına oturur.